

SIMULACION Y MITIGACION DE ATAQUE DOS (PRUEBA DE CARGA)

Qué es Hping3?

Hping3 es una aplicación de terminal para Linux que permite analizar y ensamblar paquetes TCP/IP con facilidad. A diferencia de un ping convencional, que envía paquetes ICMP, Hping3 permite el envío de paquetes TCP, UDP y RAW-IP. Esto lo convierte en una herramienta mucho más versátil que el ping básico, ideal para una variedad de tareas de seguridad y pruebas de red.

Hping3 puede utilizarse para:

- Probar la seguridad y el funcionamiento de los firewalls
- Realizar escaneos avanzados de puertos, aunque Nmap es más adecuado para esta tarea
- Probar redes usando diferentes protocolos, ToS, fragmentación, etc.
- Descubrir el MTU en la ruta de forma manual
- Realizar Traceroute avanzado usando todos los protocolos admitidos
- Obtener la huella digital remota del sistema operativo
- Comprobar el tiempo de distancia

Qué es Fail2ban?

Para evitar los ataques de fuerza bruta tenemos aplicaciones como **Fail2ban**, las cuales podemos configurar para que se encarguen de monitorizar todos los accesos a los servicios online de un servidor.

Al monitorizar todos los accesos, podemos decidir cuántas veces puede una misma dirección IP intentar un acceso a un servicio con credenciales erróneas. Después de llegar al límite establecido, **Fail2ban puede banear (bloquear) la dirección IP** durante un tiempo establecido, para un servicio específico.

De esta forma evitamos que una misma dirección IP pruebe constantemente el acceso a nuestro servidor o a cualquier otro servicio ya que supone un riesgo y, además, un **consumo de recursos del servidor**.

Vamos a simular un ataque al puerto 22 ssh

1- Instalacion de aplicaciones

Instalar Hping3

```
sudo apt install hping3 -y
```

Instalar Fail2ban

```
sudo apt install fail2ban
```

2- Configuración de Fail2Ban para Monitorear el Puerto SSH

a. Crear el Archivo de Configuración Local

i. `sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local`

b. Configurar el Jail para SSH

i. `sudo nano /etc/fail2ban/jail.local`

```
[sshd]
enabled = true
port = ssh
filter = sshd
logpath = /var/log/auth.log
maxretry = 3           # Bloquear tras 3 intentos fallidos
bantime = 600          # Bloqueo por 10 minutos
findtime = 60          # Tiempo en el que se cuentan los intentos (1 minuto)
```

c. Reiniciar Fail2Ban para Aplicar los Cambios

i. `sudo systemctl restart fail2ban`

3- Simulación de la Prueba de Carga con Hping3

a. Ejecutar Hping3 para Simular la Carga en el Puerto 22

i. `sudo hping3 -S --flood -p 22 192.168.x.x`

4- monitorea el trafico de red con wireshark

5- Verificar que Fail2Ban Bloquee la IP de la Prueba de Carga

a. `sudo fail2ban-client status sshd`

6- Consultar el Log de Fail2Ban

a. `sudo tail -f /var/log/fail2ban.log`

Dime que conclusiones tienes sobre este ejercicio.

Con la aplicación hydra, realiza un intento de acceso al servicio ssh

```
hydra -l invaliduser -p wrongpassword <ip del servidor> ssh
```